Auditoría técnica de cumplimiento — Sterclicks

Revisión directa del repositorio (CodeIgniter 4, hosting Hostinger) · 14 de agosto de 2026 · Documento de trabajo interno, no sustituye una auditoría de seguridad profesional ni asesoramiento legal

Aviso general: el `.env` local revisado tiene `CI_ENVIRONMENT = development` y `baseURL` apuntando a `localhost`. No se ha podido verificar el `.env` real del servidor de producción en Hostinger desde este entorno — debe comprobarse manualmente allí.

Nota sobre las secciones D y F: el cuestionario original asume componentes (`ConsentController`, `marketing_consent`, `BackupService`, `BackupController`, `BackupModel`, `RunBackup`, `aws/aws-sdk-php`) que **no existen en absoluto** en este repositorio — ni en controladores, ni en modelos, ni en `composer.json`. No están mal configurados: simplemente no se han construido todavía.

A. Autenticación y gestión de contraseñas

Ítem	Estado	Archivo(s)	Acción recomendada
Hash con password_hash (bcrypt/argon2)	CUMPLE	`app/Config/Auth.php (hashAlgorithm=PASSWORD_DEFAULT, cost 12), gestionado por Shield`	—
Login con password_verify	CUMPLE	`Shield Session authenticator; ProfileController::deleteAccount`	—
Rate limiting de login	CUMPLE	`app/Config/Routes.php:84 — filtro auth-rates (Shield), 10 peticiones/min por IP`	—
Política de complejidad de contraseña	CUMPLE	`app/Config/Auth.php — min 8, CompositionValidator, NothingPersonalValidator, DictionaryValidator`	Opcional: activar PwnedValidator (está comentado)
Recuperación de contraseña (token único, expiración corta)	CUMPLE	`app/Config/Auth.php — magic link Shield, magicLinkLifetime=1h, un solo uso`	—
2FA para el panel admin	NO CUMPLE	`app/Config/Auth.php:102-105 — 'login' => null`	Activar Email2FA de Shield al menos para el grupo admin
Expiración de sesión + logout server-side	CUMPLE	`app/Config/Session.php (expiration=7200); AuthController::logout()`	—

B. Inyección SQL, XSS y CSRF

CRÍTICO

Ítem	Estado	Archivo(s)	Acción recomendada
Query Builder / consultas preparadas	CUMPLE	`No se encontró ningún $this->db->query() en app/`	—

SQL con interpolación directa de variables	NO APLICA	–	No se detectaron patrones de riesgo
CSRF activado globalmente	CUMPLE	`app/Config/Filters.php:78-83 — csrf en globals[before], excepción única (admin/products/upload_images, ya protegida por filtro admin)`	—
Formularios POST con csrf_field()	CUMPLE	`64 apariciones en app/Views`	Revisar en cada formulario nuevo
Salida escapada con esc()	PARCIAL	`register.php, payment_summary.php, etc. usan esc(); no hay revisión exhaustiva en todas las vistas admin`	Auditar campos de texto libre del cliente en vistas admin
Cabeceras de seguridad HTTP (CSP, X-Content-Type-Options, X-Frame-Options, Referrer-Policy)	NO CUMPLE	`app/Config/App.php:202 (CSPEnabled=false); app/Config/Filters.php:86 (secureheaders comentado)`	Descomentar 'secureheaders' en globals[after] y activar CSPEnabled=true ajustando la política a los CDNs usados (jQuery, Bootstrap, Font Awesome)
Validación del formulario de personalización y checkout	CUMPLE	`PersonalizarController::submitRequest; CheckoutController`	—

C. HTTPS y configuración del entorno

CRÍTICO

Ítem	Estado	Archivo(s)	Acción recomendada
Forzar HTTPS en todo el sitio	CUMPLE (en producción)	`app/Config/App.php:161 — forceGlobalSecureRequests= (ENVIRONMENT==='production')`	Verificar en el servidor real que CI_ENVIRONMENT=production
Cabecera HSTS activa	DEPENDE	`Filtro ForceHTTPS de CI4 la envía automáticamente si forceGlobalSecureRequests está activo`	Confirmar en producción con curl -I que llega Strict-Transport-Security
forceGlobalSecureRequests = true	CUMPLE CONDICIONAL	`app/Config/App.php:161`	Solo es true si ENVIRONMENT=production en el servidor
CI4 en modo production en el servidor real	NO VERIFICABLE / RIESGO	`.env local está en development`	Comprobar manualmente en Hostinger que el .env de producción tiene CI_ENVIRONMENT=production
.env no accesible públicamente + en .gitignore	CUMPLE (con matiz)	`.gitignore:16; no trackeado actualmente en git`	Ver hallazgo crítico sobre el archivo "env" (sin punto), más abajo
writable/ no accesible públicamente	CUMPLE	`writable/.htaccess — Require all denied / Deny from all; excluido en .gitignore`	—
Cabecera de versión de servidor/PHP oculta	NO VERIFICABLE DESDE EL CÓDIGO	`Se configura en Apache/php.ini, no en el repo`	Comprobar en Hostinger: expose_php=Off, ServerTokens

> **Hallazgo crítico adicional (no estaba en la checklist original):** existe un archivo llamado env (sin punto) en la raíz del repo, trackeado en git y no cubierto por `.gitignore` (que solo excluye `.env`). Su contenido es la plantilla de ejemplo de CodeIgniter (casi todo comentado) — no hay fuga de secretos reales, pero el historial de commits ("Cambio en el fichero env por .env error 500 que daba") sugiere que hubo confusión entre env y `.env` en el pasado, justo el tipo de error que causa fugas accidentales. Se revisó también el historial completo de `.env`: nunca llegó a estar en git con datos reales.
>
> Además, el `.htaccess` de la raíz del proyecto está vacío. Como `baseURL` apunta a `.../public/`, el DocumentRoot del hosting parece ser la raíz del proyecto, no `public/`. Si es así, `composer.json`, `app/`, `vendor/` y el archivo env podrían ser accesibles directamente por URL salvo que Hostinger lo bloquee a nivel de configuración. **Acción recomendada:** verificar que el DocumentRoot apunta a `public/`, o añadir un `.htaccess` de raíz que deniegue todo salvo `public/`.

D. RGPD — consentimiento y derechos de usuarios

Ítem	Estado	Archivo(s)	Acción recomendada
ConsentController, marketing_consent, marketing_consent_log	NO EXISTE	No hay ningún archivo ni columna con ese nombre en el proyecto	Construir desde cero antes de enviar marketing por email
Envíos de marketing comprobando consentimiento en el momento del envío	NO APLICA	No existe sistema de marketing por email	—
Mecanismo de baja (unsubscribe)	NO APLICA	No hay envíos de marketing implementados	—
Endpoint/proceso para derechos ARCO/ARSULIPO	PARCIAL (manual)	app/Views/frontend/privacy.php:45-46 remite a Contacto	Cumple el mínimo; documentar internamente el procedimiento de respuesta
Eliminación/anonimización real al borrar cuenta	PARCIAL	ProfileController::deleteAccount() anonimiza users/auth_identities y borra direcciones, pero los pedidos conservan los datos personales intencionadamente	Defendible por obligación contable, pero documentarlo explícitamente en la política de privacidad
Checkbox de marketing no premarcado, separado de T&C	NO APLICA	No existe checkbox de marketing en register.php	—
Enlaces legales visibles antes de enviar el formulario de registro	NO CUMPLE	app/Views/frontend/register.php — sin enlaces legales ni checkbox de aceptación	Añadir checkbox obligatorio "He leído y acepto los Términos y la Política de Privacidad"

E. Gestión de cookies

Ítem	Estado	Archivo(s)	Acción recomendada
Inventario de cookies	CUMPLE	Solo sterclicks_session y sterclicks_remember, ambas técnicas. Confirmado en cookies.php:18	—

Banner de consentimiento de cookies	NO EXISTE, PROBABLEMENTE NO NECESARIO	`No hay banner en header.php/footer.php`	No exigido para cookies técnicas; si se añade analítica/marketing en el futuro, pasa a ser obligatorio
Botón "Rechazar" igual de visible que "Aceptar"	NO APLICA	`No hay banner`	—
Ninguna cookie no esencial antes de consentimiento	CUMPLE	`No hay cookies de analítica/marketing en el código`	—
Revocación fácil del consentimiento	NO APLICA	`No hay cookies no esenciales que revocar`	—

F. Sistema de copias de seguridad

Ítem	Estado	Archivo(s)	Acción recomendada
BackupService, RunBackup, BackupController, BackupModel, aws/aws-sdk-php, backup.* en .env, rutas admin/backups/*, spark backup:run, cron hPanel, retención	NO EXISTE	`Ningún archivo, ruta ni dependencia relacionada en todo el repositorio`	Hallazgo más importante desde el punto de vista de continuidad de negocio: no hay backup automatizado de la BD. Confirmar primero si Hostinger ya ofrece backups a nivel de hosting como mitigación mientras se construye algo propio

G. Pagos y logística

Ítem	Estado	Archivo(s)	Acción recomendada
El número de tarjeta nunca pasa por un endpoint propio	CUMPLE (con matiz)	`No existe PaymentController ni cobro online activo; CheckoutController::confirmOrder() deja el pedido en Pending y el pago se gestiona manualmente después`	—
No se guardan datos de tarjeta en logs/BD	CUMPLE	`Sin referencias a card/cvv/pan en controladores o modelos`	—
Packlink PRO transmite solo datos necesarios	CUMPLE (aparentemente)	`app/Controllers/Admin/ShippingController.php — solo CP/país origen y destino`	—

Nota funcional (no estaba en la checklist): composer.json incluye stripe/stripe-php y el .env tiene claves de Stripe de test, y CLAUDE.md describe a Stripe como el método de pago implementado. Esto ya no es así en el código actual: el checkout no invoca Stripe en ningún punto — el pago pasó a ser 100% manual/offline. Si es un cambio de producto intencionado, conviene actualizar CLAUDE.md; si no lo es, es un hallazgo funcional a revisar.

H. Información al consumidor en el checkout

Ítem	Estado	Archivo(s)	Acción recomendada
Precio total, envío desglosado y plazo de entrega antes de pagar	NO CUMPLE	`app/Views/frontend/checkout/payment_summary.php` — solo total de artículos	Añadir línea de envío (o nota "a confirmar") y plazo estimado antes del botón "Confirmar pedido"
Aviso de exclusión del derecho de desistimiento (art. 103.c TRLGDCU) antes de confirmar	NO CUMPLE	Solo mencionado indirectamente en terms.php sección 5	Añadir aviso explícito en payment_summary.php antes del botón de confirmar
Email de confirmación de pedido con detalle completo	CUMPLE	`CheckoutController::confirmOrder()` — emails/payment_confirmation y emails/copy_order	—
Enlace a la plataforma ODR de la UE	NO CUMPLE	Sin referencias a ODR / ec.europa.eu/consumers/odr en ninguna vista	Añadir el enlace en footer o en condiciones/contacto (obligatorio en comercio electrónico UE)

I. Logs y trazabilidad

Ítem	Estado	Archivo(s)	Acción recomendada
Log de accesos al panel admin (quién, cuándo, IP)	NO CUMPLE	`app/Filters/AdminFilter.php` — solo redirige, no registra nada	Añadir log_message('info', ...) o tabla dedicada en AdminFilter::before() con user id, IP y ruta
Logs no registran datos sensibles en texto plano	CUMPLE	Sin log_message con password/token/secret	—
Rotación/retención de logs	NO CUMPLE	`app/Config/Logger.php` — FileHandler estándar, un archivo por día, sin purga automática	Añadir tarea cron de limpieza (ej. find writable/logs -mtime +90 -delete) o comando spark propio

Resumen de prioridades

1. **Verificar en Hostinger:** CI_ENVIRONMENT=production, DocumentRoot apuntando a public/ (o .htaccess de raíz que bloquee el resto), y probar GET /.env y GET /env directamente contra el dominio en producción.
2. **No hay backups automatizados** (sección F) — el hueco más grave de continuidad de negocio.
3. **Checkout:** falta desglose de envío/plazos y el aviso de exclusión de desistimiento antes de confirmar (sección H).
4. **Cabeceras de seguridad HTTP** (CSP, X-Frame-Options, etc.) desactivadas — activar secureheaders es un cambio de una línea con impacto real en XSS/clickjacking.
5. **Registro sin checkbox** de aceptación de Términos/Privacidad (sección D).